

1-cuestionario-de-proveedores

third-party-contracts/1-cuestionario-de-proveedores.docx

Cuestionario de Evaluación de Cumplimiento en Materia de Protección de Datos Personales para Proveedores de Servicios de Grünenthal.

CLASIFICACIÓN DEL DOCUMENTO

Interno

REFERENCIA

[Inserte Referencia]

VERSIÓN

1

FECHA

[Inserte fecha]

AUTOR DEL DOCUMENTO

[Inserte nombre]

PROPIETARIO DEL DOCUMENTO

[Inserte nombre]

Historial de revisiones

VERSIÓN

FECHA

AUTOR DE REVISIÓN

RESUMEN DE LOS CAMBIOS REALIZADOS

Distribución

NOMBRE

TÍTULO

Aprobación

NOMBRE

PUESTO

FIRMA

FECHA

CONTENIDO

1.	Introducción	4
2.	Definiciones de Utilidad	5
3.	Instrucciones	7
4.	Cuestionario	7
1.	Información General del Proveedor	7
2.	Descripción de los Servicios y Datos Sujetos al Tratamiento	8
3.	Mecanismos para demostrar el cumplimiento de la Normatividad	10
4.	Factores para establecer las medidas de seguridad	11

5.	Controles generales	12
6.	Actualización de las medidas de Seguridad	14
7.	Medidas de Seguridad Físicas	15
8.	Medidas de Seguridad Técnicas	16
9.	Medidas de Seguridad Administrativas	19
10.	Protocolo para la Atención de Vulneraciones de Seguridad	20
11.	Destrucción Segura de los Datos Personales	21
12.	Contratación de Servicios de Cómputo en la Nube	22
13.	Información Adicional	22
5.	Resultados (para llenar exclusivamente por Grünenthal)	24

Introducción

El presente Cuestionario de Evaluación está dirigido a cualquier empresa, nacional o extranjera (en adelante, el “Tercero” o “Proveedor”), que preste servicios a Grünenthal de México, S.A. de C.V. (“Grünenthal”), en el marco de los cuales pudiera llevarse a cabo el tratamiento de Datos Personales.

Definiciones de Utilidad

Para efecto del presente, los términos que se presentan en la siguiente tabla tendrán la definición que se precisa a continuación:

Término

Definición

Dato Personal

Cualquier información concerniente a una persona identificada o identificable. Se considera que una persona es identificable cuando su identidad pueda determinarse directa o indirectamente a través de cualquier información.

Datos Personales Sensibles

Aquellos datos personales que afecten a la esfera más íntima de la persona titular, o cuya utilización indebida pueda dar origen a discriminación o conlleve un riesgo grave para esta. De manera enunciativa más no limitativa se consideran sensibles los datos personales que puedan revelar aspectos como origen racial o étnico, estado de salud presente o futuro, información genética, creencias religiosas, filosóficas y morales, opiniones políticas y preferencia sexual.

Derechos ARCO

Son los derechos de acceso, rectificación, cancelación y oposición que puede ejercer el titular de los Datos Personales. Adicionalmente se consideran los derechos de revocación de consentimiento y limitación de uso y/o divulgación de los Datos Personales.

Ley/LFPDPPP

Ley Federal de Protección de Datos Personales en Posesión de Particulares, publicada en marzo del 2025.

Medidas de Seguridad Administrativas

Conjunto de acciones y mecanismos para establecer la gestión, soporte y revisión de la seguridad de la información a nivel organizacional, la identificación y clasificación de la información. Asimismo, la concientización, formación y capacitación del personal en materia de protección de datos personales.

Medidas de Seguridad Técnicas

Conjunto de actividades, controles o mecanismos con resultado medible, que se valen de la tecnología para asegurar que:

El acceso a las bases de datos lógicas o a la información en formato lógico sea por usuarios identificados y autorizados.

El acceso referido en el inciso anterior sea únicamente para que el usuario lleve a cabo las actividades que requiere con motivo de sus funciones.

Se incluyan acciones para la adquisición, operación, desarrollo y mantenimiento de sistemas seguros, y

Se lleve a cabo la gestión de comunicaciones y operaciones de los recursos informáticos que se utilicen en el tratamiento de datos personales.

Medidas de Seguridad Físicas

Conjunto de acciones y mecanismos que tienen el objetivo de:

Prevenir el acceso no autorizado, el daño o interferencia a las instalaciones físicas, áreas críticas de Grünenthal, equipo e información.

Proteger los equipos móviles, portátiles o de fácil remoción, situados dentro o fuera de las instalaciones.

Proveer a los equipos que contienen o almacenen datos personales de un mantenimiento que asegure su disponibilidad, funcionalidad e integridad, y

Garantizar la eliminación de datos de forma segura.

Personal Autorizado

Los usuarios que han recibido autorización para interactuar con uno o más sistemas de información de Grünenthal.

Responsable

Personas físicas o morales de carácter privado que llevan a cabo el tratamiento de datos personales.

Persona encargada

Persona física o jurídica que sola o conjuntamente con otras trate datos personales por cuenta del responsable.

Tercero Autorizado

Persona física o moral, nacional o extranjera, distinta de la persona titular, de Grünenthal o del Encargado.

Titular

Persona a quien corresponden los datos personales.

Tratamiento

Cualquier operación o conjunto de operaciones efectuadas mediante procedimientos manuales o automatizados aplicados a los datos personales, relacionadas con la obtención, uso, registro, organización, conservación, elaboración, utilización, comunicación, difusión, almacenamiento, posesión, acceso, manejo, aprovechamiento, divulgación, transferencia o disposición de datos personales.

Instrucciones

Responda a todas las preguntas del presente documento, justificando su respuesta en cada una de las preguntas que se le formulan. En caso de que considere que una pregunta no le aplica, será necesario que justifique su respuesta.

Favor de proporcionar la documentación necesaria para acreditar el cumplimiento de los reactivos de este documento.

Cuestionario

Información General del Proveedor

Nombre Comercial del Proveedor:

Denominación / Razón Social

Domicilio para oír y recibir notificaciones:

Nombre y cargo de la persona que proporciona la información:

Correo electrónico:

Teléfono:

Sitio web de la organización revisada:

Nombre de quien realiza la revisión:

Cargo de quien realiza la revisión:

Fecha de la evaluación:

Descripción de los Servicios y Datos Sujetos al Tratamiento

Tema

Pregunta

Respuesta

Servicios y datos sujetos a tratamiento

Realice una descripción general de los servicios que prestará a Grünenthal?

¿En qué sector de actividad identifica los servicios que prestará a Grünenthal?

Para prestar los servicios requeridos, ¿hará uso de datos personales?

En caso de haber contestado afirmativamente a la pregunta anterior, indique qué tipo de datos tratará.

Indique la finalidad para la que se le dará tratamiento a estos datos.

¿La organización le dará tratamiento a datos personales patrimoniales y/o financieros?

En caso de haber contestado afirmativamente a la pregunta anterior, indique qué tipo de datos tratará.

Indique la finalidad para la que se le dará tratamiento a estos datos.

¿La organización tratará datos personales sensibles?

En caso de haber contestado afirmativamente a la pregunta anterior, indique qué tipo de datos personales sensibles tratará y la finalidad de su tratamiento.

Los datos sensibles pueden incluir, pero no se limitan a: Origen racial o étnico, estado de salud presente o futuro, información genética, creencias religiosas, filosóficas y morales, afiliación sindical, opiniones políticas, preferencia sexual, entre otros que puedan poner en riesgo al titular de ser sujeto a discriminación.

¿Hará uso de datos que originalmente eran personales pero que se han borrado campos de tal manera que ya no es posible identificar a la persona?

De ser así, señale cuáles son y las finalidades de su tratamiento.

Mecanismos para demostrar el cumplimiento de la Normatividad

Tema

Pregunta

Respuesta

Cumplimiento a la normatividad

1. ¿La organización cuenta con certificaciones de protección de datos personales? De ser así indique cuáles son, así como la identidad del tercero que las emite y su vigencia.
2. ¿La organización cuenta con certificaciones de seguridad de la información? De ser así indique cuáles son, así como la identidad del tercero que las emite y su vigencia.
3. ¿La organización se ha adherido a algún esquema de autorregulación vinculante reconocido por la Secretaría de Anticorrupción y Buen Gobierno?
4. ¿La organización se ha adherido a algún esquema de certificación sectorial específico?
5. ¿La organización se ha adherido a algún esquema de certificación internacional? De ser así indique cuáles son, así como la identidad del tercero que las emite y su vigencia.
6. ¿La organización cuenta con un Comité de Privacidad u órgano similar?

En caso afirmativo indique las áreas que lo integran

7. ¿La empresa ha designado un Oficial, Departamento, Delegado o Responsable de la Protección de Datos?

8. ¿La organización cuenta con área de seguridad de la información?

9. ¿La organización cuenta con otras áreas involucradas en la privacidad y protección de datos?

Factores para establecer las medidas de seguridad

Tema

Pregunta

Respuesta

Factores para establecer las medidas de seguridad

1. ¿Ha considerado el riesgo inherente a la naturaleza de los datos para establecer las medidas de seguridad?

2. ¿Ha considerado la sensibilidad de los datos para establecer las medidas de seguridad?

3. ¿Ha considerado el desarrollo tecnológico para establecer las medidas de seguridad?

4. ¿Ha considerado las posibles consecuencias en caso de vulneración para establecer las medidas de seguridad?

5. ¿Ha considerado el número de titulares para establecer las medidas de seguridad?

6. ¿Ha considerado las vulnerabilidades previas ocurridas en los sistemas de tratamiento para establecer las medidas de seguridad?

7. ¿Ha considerado el riesgo por el valor potencial cuantitativo o cualitativo que pudieran tener los datos personales tratados para una tercera persona no autorizada para su posesión para establecer las medidas de seguridad?

8. ¿Ha considerado otros factores o elementos para establecer las medidas de seguridad?

Controles generales

Tema

Pregunta

Respuesta

Controles generales

1. ¿Ha elaborado un inventario de datos personales y de los sistemas de tratamiento?
2. ¿Ha determinado las funciones y obligaciones de las personas que traten datos personales?
3. ¿Cuenta con un análisis de riesgos de datos personales que consiste en identificar peligros y estimar los riesgos a los datos personales?
4. ¿Ha establecido las medidas de seguridad aplicables a los datos personales e identificado aquéllas implementadas de manera efectiva?
5. ¿Ha realizado el análisis de brecha sobre las medidas de seguridad?
6. ¿Ha elaborado un plan de trabajo para la implementación de las medidas de seguridad faltantes, derivadas del análisis de brecha?
7. ¿Realiza revisiones o auditorías? De ser así, señale la periodicidad de estas.
8. ¿Se revisan los hallazgos de las auditorías y se hacen cumplir?
9. ¿Ha capacitado al personal que realiza el tratamiento de datos personales, seguridad de la información o temas afines?

En caso de haber contestado afirmativamente a la pregunta anterior, indique qué tipo de capacitaciones recibe el personal.

En relación con la pregunta anterior, responda ¿Con qué frecuencia realiza las capacitaciones al personal?

10. ¿Las capacitaciones las realiza personal de la organización o un tercero? En caso de que un tercero realice

las capacitaciones, indique cuál es la identidad de este.

11. ¿Mantiene un registro de los medios de almacenamiento de los datos personales?

12. ¿Cuenta con una relación de las medidas de seguridad derivadas de las fracciones anteriores?

13. ¿Cuenta con un sistema de gestión de seguridad de datos personales?

14. ¿La organización cumple con algún estándar de seguridad? Favor de informar cuál(es) y su alcance.

Actualización de las medidas de Seguridad

Tema

Pregunta

Respuesta

Actualización

1. ¿Se actualizan las medidas de seguridad cuando se modifican las medidas o procesos de seguridad para su mejora continua, derivado de las revisiones a la política de seguridad?

2. ¿Se actualizan las medidas de seguridad cuando se producen modificaciones sustanciales en el tratamiento que deriven en un cambio del nivel de riesgo?

3. ¿Se actualizan las medidas de seguridad cuando se vulneran los sistemas de tratamiento?

4. ¿Se actualizan las medidas de seguridad cuando existe una afectación a los datos personales distinta a las anteriores?

Medidas de Seguridad Físicas

Tema

Pregunta

Respuesta

Medidas físicas

1. ¿Cuenta con mecanismos para limitar el ingreso físico a las instalaciones? Señale cuales.
2. ¿Cuenta con bitácoras de registro para el personal que ingresa a la organización?
3. ¿Los sistemas de almacenamiento físico se protegen con candados y cerraduras o mecanismos similares?
4. ¿Se han establecido alarmas?
5. ¿Se cuenta con sistema de videovigilancia en las instalaciones?
6. ¿Existe personal de vigilancia que revise el acceso a las instalaciones?
7. ¿Se utilizan maletines para transportar equipos de cómputo o dispositivos?
8. ¿Se cuenta con registro de entrada/salida de dispositivos?
9. ¿Se utilizan servicios de mensajería certificada para el envío de documentos?
10. ¿Existen controles adicionales de los anteriores? En su caso, favor de señalar cuáles son.

Medidas de Seguridad Técnicas

Tema

Pregunta

Respuesta

Medidas técnicas

1. ¿Las políticas de seguridad de la información, incluyendo las políticas de control de acceso, desarrollo de aplicaciones y sistemas, de seguridad operativa, de redes y física con las que cuenta se encuentran formalmente

documentadas?

2. ¿Se utilizan contraseñas y/o cifrado para restringir el acceso a los datos personales y/o sistemas de tratamiento electrónicos?

3. ¿Los equipos de cómputo utilizan contraseñas y/o cifrado?

4. ¿Se cuenta con registro de usuarios y acceso a sistemas de tratamiento?

5. ¿Se ha instalado un escáner de virus en cada uno de sus servidores y cada una de las estaciones de trabajo?
¿El escáner de virus se actualiza de manera regular?

De ser así, ¿cuál es la última versión instalada en los servidores y en los equipos de cómputo?

6. ¿Se hace uso de la encriptación para el envío de correos y documentos electrónicos?

7. Al autenticar a través de Internet, la aplicación se encuentra diseñada para prevenir que usuarios con intenciones maliciosas traten de identificar usuarios existentes?

8. ¿Se han instalado herramientas anti-malware y de filtrado de tráfico (firewall o muro de protección)?

9. ¿Se realizan respaldos de datos personales?

De ser así, ¿Qué tipo de respaldos y con qué periodicidad se realizan?

10. ¿Se realiza el bloqueo y cierre de sesiones?

11. ¿Cuenta con una política de calidad de contraseñas?

12. ¿Se restringe el uso de servicios web, sitios y aplicaciones?

De ser así, señale de qué forma se restringe el acceso.

13. ¿Se usan comunicaciones seguras, encriptadas, para la administración remota de los sistemas de producción y aplicaciones?

14. En caso de tratar datos patrimoniales, ¿Está prohibido guardar el código de validación (tres dígitos, impresos

en el panel de firma de una tarjeta) en bases de datos, archivos de bitácora y registros o productos de punto de venta?

15. ¿Se enmascaran todos los dígitos del número de cuenta, excepto los últimos cuatro, al desplegar los datos de los tarjetahabientes?

16. ¿Se guardan en forma segura los números de cuenta (en bases de datos, registros, bitácoras, archivos, medios de respaldo, etc.), por ejemplo, mediante encriptación o truncando los números?

17. ¿Se almacenan en cookies, de forma segura o encriptada, los datos confidenciales de los tarjetahabientes?

18. ¿Se establecen reglas de navegación segura?

19. ¿Se actualizan los dispositivos y equipos de cómputo? Si es así, ¿Con qué periodicidad los actualiza?

20. ¿Se revisa periódicamente el software instalado en el equipo de cómputo?

21. ¿Se hace uso de la encriptación o mecanismos similares para proteger los dispositivos de almacenamiento?

22. ¿Se revisa la configuración de seguridad del equipo de cómputo?

23. ¿El personal externo está sometido a los mismos controles que el personal interno?

24. Si se usa la tecnología inalámbrica, ¿se encripta la comunicación utilizando Wi-Fi Protected Access (WPA), VPN, SSL de 128 bits, o WEP?

25. Si se usa la tecnología inalámbrica, ¿se usan tecnologías de encriptación adicionales como WEP de 128 bits y se rotan trimestralmente las claves WEP compartidas?

26. ¿Se encriptan las transmisiones de datos confidenciales de los tarjetahabientes a través de redes públicas mediante el uso de SSL u otros métodos aceptables de la industria?

27. Si se utiliza SSL para la transmisión de datos confidenciales de los tarjetahabientes, ¿Qué versión se usa?

28. ¿Se usa la encriptación en la transmisión de números de cuenta por correo electrónico?

29. ¿El negocio desarrolla y/o tiene sistemas para el manejo, almacenamiento y control de las transacciones que usen datos de los tarjetahabientes?

30. ¿Se actualizan los sistemas de desarrollo, prueba y producción con los parches de seguridad más recientes que proporcionan los proveedores?

31. ¿Existen controles adicionales a los anteriormente mencionados? En su caso, favor de indicar cuáles son.

32. ¿Cuenta con equipo de cómputo adquirido o armado?

33. ¿Cuenta con servidores propios o tercerizados?

34. ¿Cuenta con servidores en la nube para almacenar datos personales?

Medidas de Seguridad Administrativas

Tema

Pregunta

Respuesta

Medidas administrativas

1. ¿Los contratos laborales establecen la obligación de confidencialidad de datos personales?

2. ¿Los empleados firman cartas compromiso sobre uso y acceso de sistemas?

3. ¿Los empleados firman cartas compromiso sobre uso de datos personales?

4. ¿Los empleados firman cartas compromiso sobre uso de sistemas y equipos de cómputo?

5. ¿Los terceros proveedores de servicios firman convenios de confidencialidad?

6. ¿Se realiza la evaluación de terceros proveedores de servicios?

7. ¿Cuenta con políticas de protección de datos? En su caso, favor de enlistarlas.

8. ¿Cuenta con política de escritorios limpios?

9. ¿Cuenta con política sobre uso de dispositivos móviles?

10. ¿Cuenta con bitácoras de gestión de usuarios y accesos?

11. ¿Se realiza una investigación de antecedentes (como antecedentes de crédito dentro de los límites de las leyes locales) para puestos específicos?

12. ¿Existen controles adicionales a los anteriormente mencionados? En su caso, favor de enlistarlos.

Protocolo para la Atención de Vulneraciones de Seguridad

Tema

Pregunta

Respuesta

Atención de vulneraciones

1. ¿Se cuenta con un protocolo de atención de vulneraciones de seguridad?

2. ¿La organización ha constituido un equipo responsable de la atención de medidas de seguridad?

3. ¿Qué medidas de mitigación pueden aplicarse en caso de vulneración?

4. ¿Qué medidas de corrección pueden aplicarse en caso de vulneración?

5. ¿Qué medios se tienen para notificar a Grünenthal sobre las vulneraciones de seguridad ocurridas?

6. ¿Cuenta con un equipo estructurado para atender vulneraciones de seguridad?

Destrucción Segura de los Datos Personales

Tema

Pregunta

Respuesta

Destrucción

1. ¿Qué mecanismos implementa para la destrucción segura de datos personales en soportes físicos?
2. ¿Qué mecanismos implementa para la destrucción segura de datos personales en soportes electrónicos?
3. ¿Contrata terceros para realizar actividades de destrucción segura de datos personales? De ser así informe cuáles.
4. ¿Cuenta con una política de cancelación/destrucción de datos personales?
5. ¿Qué mecanismos tiene para notificar los Derechos ARCO que ejerzan los titulares de Grünenthal?

Contratación de Servicios de Cómputo en la Nube

Tema

Pregunta

Respuesta

Medidas técnicas

1. ¿El Proveedor de prestación de servicios de cómputo en la nube es un actor reconocido en el mercado? ¿Cuál es la opinión pública que existe en torno a sus servicios?
2. ¿El Proveedor o algún subcontratista sufrido incidentes de seguridad importantes?
3. ¿Se han denunciado de manera pública medidas de seguridad deficientes del Proveedor o de alguna entidad subcontratada?
4. ¿El Proveedor o sus subcontratistas han sido sujetos de denuncias o investigaciones por autoridades de

protección de datos personales?

5. ¿El Proveedor es claro y transparente respecto a su modelo de negocio?

6. ¿El Proveedor es claro y transparente respecto a sus prácticas en el tratamiento de datos personales?

7. ¿El Proveedor es claro y transparente respecto a su política de privacidad?

8. ¿La política de privacidad del proveedor es diferenciada para cada uno de los productos o servicios en la nube?

9. ¿Se identifica la jurisdicción o normatividad que rigen al Proveedor y al contrato?

10. ¿Se identifica la ubicación geográfica de los centros de tratamiento de información y en su caso la oficina de atención regional?

11. ¿Se identifica el ámbito geográfico en el cual se respalda la prestación del servicio?

12. ¿Cumple con la normativa mexicana en materia de protección de datos? ¿Cuenta con algún esquema de autorregulación, como una certificación en materia de protección de datos personales?

13. El proveedor cuenta con alguna certificación como la ISO/IEC 27018:2014 e ISO/IEC 19086-1:2016?

Información Adicional

Tema

Pregunta

Respuesta

Datos adicionales

1. ¿Ha estado involucrado en algún procedimiento ante la autoridad mexicana de protección de datos personales? En caso afirmativo señale cuál y cuándo.

2. ¿Ha sido sancionado por la autoridad mexicana de protección de datos o por alguna autoridad por un

tratamiento indebido de datos personales?

3. ¿Existe información adicional que quiera compartir con Grünenthal para llenar este cuestionario?

Resultados (para llenar exclusivamente por Grünenthal)

Evaluación final

Pregunta

Respuesta

Valoración general de cumplimiento

1. ¿El proveedor garantiza un nivel adecuado de cumplimiento a la normatividad de protección de datos personales?

2. ¿Existen riesgos legales en los que Grünenthal podría incurrir con motivo de la contratación del Proveedor?

3. ¿Se recomiendan acciones particulares para el Proveedor a fin de atender los riesgos identificados?

4. ¿En qué plazo el Proveedor deberá acreditar que ha adoptado medidas de mitigación?

5. ¿Se recomienda la contratación del Proveedor? En caso afirmativo, señale las condiciones a las que se sujeta la contratación y las medidas a cumplirse.